

Standards a kryptografie - Příprava na zkoušku

KAREL VELIČKA

25. září 2026

Obsah

1	Úvod, vztah norem a standardů, TLP	3
1.1	Norma vs. Standard	3
1.2	Standards 'De Jure' a 'De Facto'	3
1.3	Závaznost technických norem v ČR	3
1.4	Limity formálních bezpečnostních modelů (D. E. Denning)	3
1.5	Traffic Light Protocol (TLP)	4
2	De facto standardy – RFC a PKCS	4
2.1	Dokumenty RFC (Request for Comments)	4
2.2	Kategorizace a životní cyklus RFC	4
2.3	Standards PKCS (Public-Key Cryptographic Standards)	5
3	Právní úprava normalizace v ČR (Zákon č. 22/1997 Sb.)	6
4	(Mezi)národní normalizační orgány, Evropský certifikační rámec	6
4.1	Národní infrastruktura v ČR	6
4.2	Evropské normativní dokumenty a procedury přejímání	6
4.3	Mezinárodní a evropské standardizační organizace	6
4.4	Evropský certifikační rámec – Akt o kybernetické bezpečnosti (CSA)	7
4.5	Subjekty posuzování shody (CAB) a Úrovně záruky	7
5	Kritéria hodnocení bezpečnosti IT (TCSEC, ITSEC, CTCPEC, FC)	7
5.1	Základní metodologické koncepty	7
5.2	TCSEC – Oranžová kniha (Orange Book)	8
5.3	ITSC – Harmonizovaná evropská kritéria	8
5.4	CTCPEC a Federal Criteria (FC)	9
5.5	Srovnávací matice historických kritérií	9
6	Mezinárodní standard Common Criteria (ISO/IEC 15408)	9
6.1	Historický kontext a mezinárodní dohoda CCRA	9
6.2	Status CC v NATO	9
6.3	Metodologie CEM a kritický limit úrovně EAL	9
6.4	Základní hodnotící koncepty: Profil ochrany vs. Bezpečnostní cíl	10
6.5	Nová strukturální architektura standardu CC:2022	10
7	Hlubší struktura Common Criteria, úrovně EAL a schéma EUCC	10
7.1	Evoluce a verze standardu CC	10
7.2	Hierarchické stavební prvky kritérií	10
7.3	Katalogizace funkčních tříd a tříd záruk	11
7.4	Podrobná specifikace úrovně záruk EAL (Evaluation Assurance Levels)	11
7.5	Ukončení platformy SOG-IS a nástup evropského schématu EUCC	12
8	Mezinárodní norma ISO/IEC 15408 a funkční požadavky (SFR)	12
8.1	Standardizační vývoj a národní implementace ČSN	12
8.2	Struktura pěti částí normy ISO/IEC 15408:2022	12
8.3	Uživatelské skupiny a aplikace standardu v praxi	13
8.4	Srovnávací charakteristika úrovně EAL a vazba na TCSEC	13
8.5	Struktura a katalog funkčních tříd (SFR)	13

9	Hodnocení bezpečnosti podle NIST – Standardy FIPS a kryptografické tranzice	14
9.1	Institucionální rámec a postkvantová standardizace	14
9.2	FIPS 199 – Nelineární kategorizace bezpečnosti informací	14
9.3	FIPS 140-3 – Bezpečnostní požadavky na kryptografické moduly	15
9.4	Čtyři kvalitativní úrovně zabezpečení modulů	15
9.5	Katalog kryptografických tranzic NIST	15
10	Normy pro systémy managementu (ISO/IEC 27001 a rodina 27000)	16
10.1	Základní koncepty auditu a Harmonizovaná struktura	16
10.2	ČSN EN ISO/IEC 27001:2023 – Národní zavedení a migrační lhůty	16
10.3	Klasifikace a katalog norem rodiny ISO/IEC 27000	17
10.4	Předmět normy	17
10.5	Klíčové terminologické definice normy	18
10.6	Specializovaný standard ISO/IEC 18033 „Šifrovací algoritmy“	18
11	Analýza rizik (Zákon č. 264/2025 Sb. a Vyhláška č. 409/2025 Sb.)	18
11.1	Typologie analýz rizik podle ISO/IEC TR 13335 a ISO 27005	19
11.2	Procesní kroky AR podle Zákona č. 264/2025 Sb. a Vyhlášky č. 409/2025 Sb.	19
11.3	Softwarové GRC nástroje pro podporu analýzy rizik	20
11.4	Převodní terminologická matice dopadů podle NÚKIB	20
11.5	Strukturální katalogy Vyhlášky č. 409/2025 Sb.	20
12	Nový zákon o kybernetické bezpečnosti (zákon č. 264/2025 Sb.)	20
12.1	Úvod do problematiky a působnost zákona	20
12.2	Architektura prováděcích vyhlášek	21
12.3	Harmonogram plnění a třífázový model hlášení incidentů	21
12.4	Struktura a kategorizace bezpečnostních rolí	21

1 Úvod, vztah norem a standardů, TLP

1.1 Norma vs. Standard

Rozdíl mezi těmito dvěma pojmy je v odborném prostředí klíčový:

- **Norma:** Oficiální, formální dokument schválený a vydaný uznávanou autoritou (např. ISO, IEC, ...).
 - Má přísně definovaný proces tvorby, revizí a hlasování.
 - Je veřejně dostupná a má silnou právní či smluvní váhu.
 - V kontextu kybernetické bezpečnosti (nZKB) definuje „co musí být“ (např. ČSN ISO/IEC 27001 určující požadavky na ISMS).
- **Standard:** Širší a volnější pojem. Nemusí být schválen žádnou oficiální autoritou a vzniká flexibilně z praxe, komunity nebo trhu.
 - Závazný je pouze tehdy, pokud ho organizace interně přijme nebo je ukotven ve smlouvě.
 - V kontextu nZKB slouží jako dobrá praxe a doporučení „jak to udělat efektivně“ (např. CIS Controls).

1.2 Standardy 'De Jure' a 'De Facto'

Kritérium	De jure (kodifikovaný)	De facto (nekodifikovaný)
Definice	Oficiální norma schválená standardizační autoritou (ISO, ČSN, EN).	Široce používaný standard vzniklý praxí, komunitou nebo trhem.
Status	Formální, právně uznatelný dokument.	Neformální, ale často dominantní v praxi.
Proces vzniku	Přísný, formální, hlasování, revize, publikace.	Flexibilní, rychlý, řízený komunitou nebo organizací.
Příklady	ISO/IEC 27001, ISO/IEC 27002.	MITRE ATT&CK, CIS Controls, TCP/IP.
Typ obsahu	Obecné požadavky, procesy, principy.	Konkrétní techniky, postupy, kontrolní seznamy.
Závaznost	Dobrovolná, ledaže na ni odkazuje zákon, vyhláška či smlouva.	Nikdy není právně závazná sama o sobě.
Stabilita	Vysoká – revize jednou za několik let.	Nízká až střední – aktualizace podle vývoje hrozeb.

1.3 Závaznost technických norem v ČR

- Technické normy (ČSN) byly v Československu plošně **obecně závazné DO roku 1991**.
- V rámci transformace na tržní ekonomiku byla **obecná závaznost zrušena**. Normy jsou od té doby **dobrovolné**, pokud na ně výslovně neodkazuje právní předpis nebo smlouva.
- **Vztah k nZKB:** Normy nejsou obecně závazné. Právně závazné jsou pouze požadavky vyhlášky č. 82/2018 Sb. o kybernetické bezpečnosti a souvisejících předpisů.

1.4 Limity formálních bezpečnostních modelů (D. E. Denning)

Zásadní limity striktních matematických a formálních modelů v IT bezpečnosti:

1. **Teoretické limity:** Nelze vždy matematicky dokázat, že model splňuje všechny bezpečnostní podmínky.
2. **Nepoužitelnost:** Striktní matematické vlastnosti často vedou k systémům, které jsou v reálném provozu nepoužitelné.
3. **Nákladnost:** Budování systémů podle formálních modelů je extrémně drahé a časově náročné (komerční sféra je nevyužívá).
4. **Falešný pocit bezpečí:** Formální metody samy o sobě bezpečnost nezajistí – systémy bývají nejčastěji prolomeny mimo předpoklady samotného modelu.
5. **Závěr:** Reálná budoucnost a flexibilita spočívá v kontinuálním testování (hackeri), doplňkových produktech (firewally, IDS, čipové karty), vzdálených službách třetích stran a rychlém nasazování bezpečnostních záplat.

1.5 Traffic Light Protocol (TLP)

Protokol určený pro bezpečné a strukturované sdílení citlivých informací. V ČR je podpořen doporučením NÚKIB. *Upozornění:* Tento systém nenahrazuje nakládání s utajovanými informacemi ve smyslu zákona č. 412/2005 Sb.

TLP:RED	Vysoce důvěrné. Informace nesmí být poskytnuta žádné jiné osobě než té, které byla přímo určena. Další šíření je možné výhradně se souhlasem původce.
TLP:AMBER+STRICT	Omezené šíření. Informace může být sdílena výhradně v rámci vlastní organizace příjemce a pouze s osobami, které splňují podmínku <i>need-to-know</i> .
TLP:AMBER	Rozšířené omezené šíření. Informace může být sdílena v rámci organizace příjemce a také s jejími přímými partnery, striktně na základě <i>need-to-know</i> .
TLP:GREEN	Komunitní sdílení. Informace může být sdílena v rámci organizace a s partnerskými subjekty, ale nikdy ne skrze veřejně dostupné kanály . Musí být zajištěna důvěrnost komunikace.
TLP:CLEAR	Bez omezení. Informace může být volně šířena a poskytována dál (autorská práva a duševní vlastnictví původce tím nejsou dotčena).

Označení v e-mailu: Značka se uvádí přímo v předmětu zprávy (např. **Předmět: TLP:AMBER – Aktualizace hrozby**). **Označení v dokumentu:** U tištěných i elektronických dokumentů se značka musí uvádět v hlavičce i patičce každé stránky.

2 De facto standardy – RFC a PKCS

2.1 Dokumenty RFC (Request for Comments)

Dokumenty RFC představují klíčovou formu dokumentace vyvíjenou pro potřeby internetové komunity. Nejedná se o formální normy de jure (jako ISO či ČSN), ale o uznávané standardy de facto.

- **Historický kontext:** Tradice publikování RFC vznikla v roce 1969 při zprovoznění sítě ARPANET. Původní protokol NCP byl v roce 1983 definitivně nahrazen rodinou protokolů TCP/IP.
- **Původ názvu a princip:** Název „žádost o komentář“ zvolili postgraduální studenti, kteří chtěli sdílet své nápady, aniž by je formálně vnucovali autoritám. Dnes RFC vydává organizace **IETF** (Internet Engineering Task Force).
- **Základní vlastnosti RFC:**
 - **Neměnnost:** Jakmile je dokument vydán pod svým pořadovým číslem, jeho obsah, číslo ani název se již nikdy nemění.
 - **Aktualizace:** Pokud je potřeba specifikaci změnit, vydá se nové RFC s novým číslem, které v záhlaví nese příznak, že předchází dokument zneplatňuje – *“Obsolete”*
 - **Dostupnost:** Jsou zcela zdarma veřejně dostupná. Některá nesou kromě RFC čísla i označení standardu (**STD #**), což jsou typičtí představitelé de facto standardů složení z jednoho či více RFC.

2.2 Kategorizace a životní cyklus RFC

Dokumenty RFC se dělí podle svého účelu a postavení do dvou hlavních trajektorií:

1. Standards Track (Standardizační proces)

Aspiruje na to, aby se dokument stal definitivním standardem.

- **Původní model:** Měl 3 stádia: *Proposed Standard* → *Draft Standard* → *Internet Standard*.
- **Současný model (od r. 2011 – RFC 6410):** Zjednodušen na **pouze 2 stádia**:
 1. **Proposed Standard:** Návrh musí prokázat svou životaschopnost nejméně na dvou na sobě nezávislých implementacích.
 2. **Internet Standard:** Finální, definitivní podoba standardu s dostatkem provozních zkušeností.

2. Off-Track (Mimo standardizační proces)

Dokumenty, které standardy nejsou a obvykle v hierarchii nikam nepostupují. Patří sem:

- **Informational RFC:** Informativní materiály, které přinášejí vysvětlení nebo rady.
- **Experimental RFC:** Obsahují informace o protokolech a technologiích, které zatím nemají zřejmou šanci se masově ujmout.
- **Historic RFC:** Specifikace, které byly překonány následovníkem nebo se v internetu přestaly úplně používat.
- **Prototype RFC:** Řešení ve stádiu experimentu s budoucím záměrem přejít do Standards Track.

3. BCP (Best Current Practices)

Samostatná specifická řada dokumentů vyjadřující doporučené nejvhodnější postupy, stanoviska a postoje internetové komunity (např. postoj ke spamu) .

4. Aprílová RFC

Specifická humorná RFC vydávaná s datem „1 April“ jako parodie na reálné dokumenty.

2.3 Standardy PKCS (Public-Key Cryptographic Standards)

Jedná se o celosvětově uznávané *de facto standardy* pro infrastrukturu veřejného klíče (PKI), které původně vyvinula americká soukromá firma RSA Security ve spolupráci s průmyslem a akademickou obcí.

V současnosti (2023–2024) dochází k jejich integraci do moderních standardů (TLS, S/MIME), optimalizaci pro cloud (PKCS #11), blockchain a zapojení do přechodu na **postkvantovou kryptografii (PQC)** koordinovanou NISTem. Podstatná část správy vybraných specifikací byla předána otevřeným standardizačním organizacím (IETF, OASIS).

Strukturální změny v číslování

V roce 2010 došlo ke sloučení standardů **PKCS #2** a **PKCS #4** do zastřešujícího standardu **PKCS #1**. Tato čísla jsou v současnosti neobsazená. Záměry na vývoj PKCS #13 (eliptické křivky) a PKCS #14 (generátory pseudonáhodných čísel) byly definitivně opuštěny.

Označení	Název / Účel	Klíčová specifikace a vlastnosti
PKCS #1	Kryptografie založená na RSA	Definuje matematické vlastnosti, formát veřejných a soukromých klíčů v kódování ASN.1 a schémata vyplňování (padding) pro šifrování a podpisy.
PKCS #3	Výměna klíčů (Diffie-Hellman)	Protokol umožňující bezpečné vytvoření sdíleného tajného klíče přes veřejný kanál.
PKCS #5	Šifrování založené na hesle	Definuje symetrické šifrování s využitím hesla, obsahuje známou derivační funkci PBKDF2..
PKCS #6	Rozšíření syntaxe certifikátů	Uzavřen/Zastaralý. Byl plně překonán novější verzí standardu X.509 verze 3.
PKCS #7	Syntaxe kryptografických zpráv	Používá se pro podepisování a šifrování zpráv v PKI. Formulace základy pro S/MIME a standard CMS (Cryptographic Message Syntax).
PKCS #8	Uložení soukromých klíčů	Definuje formát uložení soukromých klíčů v šifrované i nešifrované podobě.
PKCS #9	Vybrané typy atributů	Definuje doplňkové typy atributů využívané v ostatních standardech (např. v PKCS #7, #8 či #10).
PKCS #10	Žádost o vydání certifikátu	Formát zpráv zasílaných certifikační autoritě (CA) s žádostí o podepsání veřejného klíče (CSR – Certificate Signing Request).
PKCS #11	Kryptografické rozhraní (Cryptoki)	API definující obecné rozhraní pro hardwarové tokeny a HSM (Hardware Security Modules). Používá se pro SSO, šifrování disků. Vývoj předán konsorciu OASIS.
PKCS #12	Syntaxe výměny osobních informací	Formát kontejneru chráněného heslem pro uložení soukromého klíče společně s jeho certifikátem (nástupce PFX). Využívá se v Java KeyStore nebo Firefoxu.
PKCS #15	Přístup k hardwarovým tokenům	Popisuje, jak aplikace pracují s hardwarovými tokeny nezávisle na PKCS #11. Část pro IC karty převzalo ISO/IEC 7816-15.

3 Právní úprava normalizace v ČR (Zákon č. 22/1997 Sb.)

Přednáškový text byl TLP:AMBER+STRICT.

4 (Mezi)národní normalizační orgány, Evropský certifikační rámec

Zde mapujeme kompetence národních institucí v oblasti standardizace a metrologie, definujeme hierarchickou strukturu evropských normativních dokumentů a popisuje architekturu nastupujícího jednotného evropského certifikačního rámce pro kybernetickou bezpečnost.

4.1 Národní infrastruktura v ČR

V České republice je implementace norem a metrologie rozdělena mezi specializované složky:

- **ÚNMZ:** Organizační složka státu v resortu MPO zřízená zákonem č. 20/1993 Sb. Zajišťuje státní správu v daných oblastech, sladí české předpisy s EU a vydává oficiální Věstník ÚNMZ.
- **ČAS:** Státní příspěvková organizace zřízená ÚNMZ (podle zákona č. 265/2017 Sb.), na kterou od 1. 1. 2018 přešly veškeré činnosti spojené s tvorbou, vydáváním a distribucí technických norem. Je plnoprávným řádným členem ISO, IEC, CEN a CENELEC.
- **ČMI:** Zřízen MPO a ÚNMZ. Zabezpečuje jednotnost a přesnost měřidel, shodu národních etalonů s mezinárodními a provádí primární etalonáž, metrologický výzkum a kalibraci v regulované i neregulované sféře.

4.2 Evropské normativní dokumenty a procedury přejímání

Při integraci evropských dokumentů do národní soustavy norem platí striktní pravidla:

- **EN (Evropská norma):** Vydávaná organizacemi CEN, CENELEC nebo ETSI. Členské státy mají **povinnost** ji zavést jako **národní normu** a současně zrušit všechny staré národní normy, které jsou **s ní v rozporu**. ČAS má na zavedení EN do národní soustavy **lhůtu půl roku**.
- **HD (Harmonizační dokument):** Zpracovává se, pokud není možné nebo účelné vytvořit plnohodnotnou EN. Státy ji musí povinně zavést alespoň formou zveřejnění jejího čísla a názvu a současně zrušit konfliktní národní normy či jejich části.
- **ENV (Předběžná evropská norma):** Určená k ověření v praxi **po dobu 3 let** (+ jednorázového prodloužení o 2 roky). Národní normy, které jsou s ní v rozporu, mohou zůstat v platnosti. V ČR se označuje jako *ČSN P ENV*.

4.3 Mezinárodní a evropské standardizační organizace

Globální úroveň

- **ISO (Mezinárodní organizace pro normalizaci):** Nezávislá nevládní organizace založená 1947 se sídlem v Ženevě. Tehdejší ČSR byla zakládajícím členem. Sdružuje 176 národních orgánů (v ČR je zástupcem ČAS). Vytváří dobrovolné konsensuální normy pro **všechna odvětví vyjma elektrotechniky**. Vydává *normy ISO, technické specifikace (TS), technické zprávy (TR) a veřejně dostupné specifikace (PAS)*.
- **IEC (Mezinárodní elektrotechnická komise):** Založena 1906, sídlí v Ženevě a sdružuje přes 80 zemí. Vytváří standardy **pro elektrotechniku, elektroniku a příbuzné technologie**. Úzce spolupracuje s ISO prostřednictvím společných technických komisí. Dokumenty se přejímají jako *ČSN IEC*

Evropská úroveň

- **CEN (Evropský výbor pro normalizaci):** Brusel; vytváří evropské normy (EN), specifikace (CEN/TS) a zprávy (CEN/TR) pro **neelektrotechnické obory**. ČR je plnoprávným členem od roku 1997 přes ČAS
- **CENELEC (Evropský výbor pro elektrotechnickou normalizaci):** Brusel, založen 1973; vytváří normy (EN) a harmonizační dokumenty (HD) **pro elektrotechnický průmysl**. Má 34 členů včetně ČR.
- **ETSI (Evropský institut pro normalizaci v telekomunikacích):** Sophia Antipolis (Francie), založen 1988. Vytváří globální standardy pro ICT (stojí za 4G, 5G). Její normy jsou pro veřejnost *dostupné zdarma*. **Důležitý detail:** Na rozdíl od CEN/CENELEC, kde je ČR plnoprávným členem, má zde ČAS (Agentura) pouze statut pozorovatele.

4.4 Evropský certifikační rámec – Akt o kybernetické bezpečnosti (CSA)

Nařízení EU 2019/881 zavádí první jednotný certifikační rámec na veřejnoprávní bázi na světě. Integruje certifikaci nejen produktů (jako historická Common Criteria), ale i služeb a procesů.

SOG-IS: Starší užší spolupráce vybraných evropských států založená na standardu Common Criteria, kde si státy vzájemně uznávaly certifikáty vyšších bezpečnostních úrovní.

ENISA (Agentura EU pro kybernetickou bezpečnost): Atény, založena 2004. Vypracovává návrhy konkrétních certifikačních schémat pod záštitou Evropské komise a s pomocí **ECCG (Evropská skupina pro certifikaci kybernetické bezpečnosti)** – složená ze zástupců členských států). Vydává pravidelné zprávy ENISA Threat Landscape (ETL) a organizuje cvičení Cyber Europe .

Aktuálně vyvíjená certifikační schémata (schémata ENISA)

1. **EUCC:** Certifikace produktů podle Common Criteria (nahrazuje SOG-IS)
2. **Cloudové služby:** Návrh jednotných bezpečnostních pravidel pro cloudová úložiště a infrastrukturu.
3. **IoT (Internet věcí):** Schéma pro zabezpečení distribuovaných spotřebních i průmyslových prvků.
4. **Procesy:** Certifikace systémových a organizačních procesů v IT.
5. **Dodavatelský řetězec:** Hodnocení SW dodavatelského řetězce (SBOM) – český návrh iniciovaný NÚKIB.

4.5 Subjekty posuzování shody (CAB) a Úrovně záruky

CAB – Conformity Assessment Body je nezávislý akreditovaný subjekt (laboratoř, certifikační orgán), který v praxi ověřuje, zda produkty či služby splňují standardy daného schématu EU .

Schvalovací proces pro CAB: CAB musí být nejdříve akreditován národním akreditačním orgánem (**ČIA** podle normy ČSN EN ISO 17025). Následně musí být příslušným státním úřadem (**NÚKIB**) *notifikován* (oznámen) Evropské komisi. Seznam aktivních CAB je evidován v evropské databázi *NANDO*.

Úrovně záruky certifikace (Assurance Levels)

Evropský rámec definuje tři úrovně záruky podle míry rizika:

ZÁKLADNÍ (Basic)	Hodnocení provádí CAB. Pokud to konkrétní schéma výslovně dovoluje, je v této úrovni možné využít i <i>vlastní posouzení shody výrobcem (self-assessment)</i> .
PODSTATNÁ (Substantial)	Vyžaduje technické prověření a verifikaci hrozeb. Certifikaci provádí výhradně nezávislý akreditovaný a notifikovaný CAB.
VYSOKÁ (High)	Vyžaduje nejvyšší míru prověření (např. penetrační testy, hloubkovou analýzu kódu). Certifikát smí vydat pouze státní autorita (NÚKIB), nebo k tomu musí CAB získat od státu dodatečnou specifickou autorizaci.

CAB certifikace budou povinné pro kritické produkty (operační systémy, firewally) podle chystaného **Aktu o kybernetické odolnosti (CRA)**, pro poskytovatele služeb vytvářejících důvěru podle nařízení eIDAS a pro schémata v rámci Aktu o kybernetické bezpečnosti (CSA).

5 Kritéria hodnocení bezpečnosti IT (TCSEC, ITSEC, CTCPEC, FC)

Zde shrneme historický vývoj a srovnání národních a regionálních kritérií, která sloužila jako formální metriky pro hodnocení a vyjádření míry bezpečnosti IT produktů a systémů před vznikem Common Criteria.

5.1 Základní metodologické koncepty

Kritéria slouží jako objektivní měřítko a metrika pro vyjádření míry bezpečnosti IT. Vládní kritéria historicky určovala směr pro komerční sféru, avšak specifická vládní kritéria pro kryptografii zůstávají často utajena.

Při certifikaci a hodnocení bezpečnosti je zásadní rozlišovat dva typy hodnocených objektů:

- **Produkt:** Samostatný SW či HW komponent, u kterého **není specifikováno** konkrétní provozní prostředí ani reálné hrozby.
- **Systém:** Větší, spojitý technologický celek, u kterého **je** při hodnocení přesně **známa** konfigurace i konkrétní provozní prostředí.

Hodnocení provádí nezávislý hodnotitel na žádost a náklady výrobce, který zároveň volí cílovou bezpečnostní úroveň a je povinen poskytnout kompletní vývojovou dokumentaci a součinnost.

5.2 TCSEC – Oranžová kniha (Orange Book)

Trusted Computer System Evaluation Criteria byla vydána Ministerstvem obrany USA v roce 1985.

- **Omezení:** Je silně ovlivněna dobou vzniku. Byla navržena pro **vojenské prostředí** a orientuje se primárně na důvěrnost informací (confidentiality) v rámci sálových počítačů. Specifika sítí a databází byla doplňována formou dodatečných interpretací (např. *Trusted Network Interpretation* – **Red Book**).
- **Pilíře hodnocení:** *Zásady* (Policy – řízení přístupu, utajení), *Odpovědnost* (Accountability – identifikace, audit) a *Záruky* (Assurance – nezávislé prověření).

Hierarchické dělení TCSEC

Systémy se klasifikují do 4 základních skupin (divizí) a 7 hierarchických tříd:

1. **Division D – Minimální ochrana:** Produkty, které sice prošly hodnocením, ale nesplnily požadavky pro žádnou z vyšších tříd.
2. **Division C – Výběrová ochrana:** Nejširší praktické využití.
 - **C1 (Discretionary Security Protection):** Výběrová ochrana na základě identity uživatelů.
 - **C2 (Controlled Access Protection):** Ochrana s řízeným přístupem. Vyžaduje auditování činností.
3. **Division B – Povinná ochrana (Mandatory Protection):** Přejít k vládním a vojenským nárokům.
 - **B1 (Labeled Security Protection):** Povinné řízení přístupu na základě stupňů utajení.
 - **B2 (Structured Protection):** Strukturovaná architektura, formalizovaná politika, kontrola skrytých kanálů a správa konfigurace.
 - **B3 (Security Domains):** Striktní oddělení bezpečnostních domén, monitorování referenčním schématem (Reference Monitor), vysoká odolnost proti průniku a obnova po havárii.
4. **Division A – Verifikovaná ochrana (Verified Protection):** Nejvyšší úroveň.
 - **A1 (Verified Design):** Vyžaduje formální, matematicky ověřený návrh systému a shodu implementace s tímto modelem. Pro většinu komerčních systémů je z finančních a procesních důvodů nedosažitelná.

5.3 ITSC – Harmonizovaná evropská kritéria

Information Technology Security Evaluation Criteria publikováno v roce 1991 Evropským společenstvím jako reakce na nedostatky TCSEC.

- **Koncepce:** Je navržen obecně pro vládní i komerční sféru a pokrývá kompletní bezpečnostní třídu **CIA** – *Důvěrnost, Integritu i Dostupnost*.
- **Inovace:** Přináší oddělení funkčnosti systému od míry jeho zaručitelnosti.

Třídy zaručitelnosti bezpečnosti (E0 až E6). Definují fixní, neměnné úrovně hloubky testování a důvěryhodnosti:

E0	Požadavky nesplněny, zaručitelnost je nedostatečná.
E1	Neformální zadání bezpečnosti, popis návrhu a funkční testy.
E2	Navíc vyžaduje neformální popis detailního návrhu a správu konfigurace.
E3	Navíc vyžaduje kompletní zpřístupnění zdrojového kódu (SW) nebo schémat zapojení (HW).
E4	Bezpečnostní politika musí být vyjádřena formálním modelem, architektura a detailní návrh semi-formálně.
E5	Striktní demonstrace úzké provázanosti mezi detailním návrhem a zdrojovým kódem.
E6	Kompletní formální popis bezpečnostní architektury konzistentní s matematickým modelem politiky a prokazatelná souvislost binárního kódu se zdrojovým textem.

Třídy funkčnosti (F-xx). Představují doporučené modelové šablony pro usnadnění práce. Pět hierarchických tříd (**F-C1**, **F-C2**, **F-B1**, **F-B2**, **F-B3**) přímo kopíruje funkční chování stejnojmenných divizí amerického standardu TCSEC. Dále definuje pět specifických, nehierarchických aplikačních tříd: **F-IN** (vysoká integrita), **F-AV** (vysoká dostupnost), **F-DI** (integrita při přenosu), **F-DC** (důvěrnost při přenosu) a **F-DX** (důvěrnost i integrita při přenosu).

5.4 CTCPEC a Federal Criteria (FC)

- **CTCPEC (Kanada):** Pokusila se o praktičtější rozdělení bezpečnostních funkcí (služeb) do 4 kategorií: *důvěrnost, integrita, dostupnost a účtovatelnost*. Úrovně v každé službě jsou nezávisle číslovány od nuly (např. autentizace WA-0 až WA-3). Úrovně záruk byly značeny *T-1 až T-6*.
- **Federal Criteria (FC – USA):** Společný projekt NIST a NSA. Přinesla zásadní koncept **Bezpečnostního profilu (Security Profile / BP)** – komplexní formalizované seskupení požadavků definující účel, podmínky použití a záruky. Rozlišovala profily pro komerční užití (ekvivalent C2) a víceúrovňovou bezpečnost (B1 až B3). Míra záruk se značí jako *T1 až T7*.

5.5 Srovnávací matice historických kritérií

Následující tabulka definuje ekvivalenci mezi jednotlivými historickými standardy:

TCSEC	ITSEC – Funkčnost	ITSEC – Záruka	CTCPEC	FC
D (min. ochrana)	—	E0	—	—
C1 (výb. přístup)	F-C1	E1	—	—
C2 (řízený přístup)	F-C2	E2	T-1	T1
B1 (ochrana návštěvím)	F-B1	E3	T-2	T2
—	—	—	T-3	T3
—	—	—	—	T4
B2 (strukt. ochrana)	F-B2	E4	T-4	T5
B3 (bezp. domény)	F-B3	E5	T-5	T6
A1 (verif. návrh)	—	E6	T-6	T7

6 Mezinárodní standard Common Criteria (ISO/IEC 15408)

Shrňme celosvětově nejuznávanější standard pro nezávislé hodnocení a certifikaci bezpečnostních vlastností IT produktů – **Common Criteria (CC)**, jenž je v ČR kodifikován pod označením **ČSN ISO/IEC 15408**.

6.1 Historický kontext a mezinárodní dohoda CCRA

Standard *Common Criteria* vznikl jako přímý nástupce a sjednocující prvek historických národních standardů: amerických TCSEC + FC, evropského ITSEC a kanadského CTCPEC. Na jeho vývoji spolupracovaly vládní a standardizační organizace šesti států: *Kanady, Francie, Německa, Nizozemska, Velké Británie a USA*.

Aby se zamezilo neustálému opakovanému testování produktů při exportu do zahraničí, byla v roce 1998 podepsána klíčová mezinárodní dohoda o vzájemném uznávání certifikátů – **CCRA (Common Criteria Recognition Arrangement)**, která dělí signatářské státy do dvou striktních skupin:

1. **Certificate Authorizing Members:** Státy provozují vlastní národní schválené schéma, mají licencované laboratoře a certifikáty sami vydávají (k březnu 2026 je jich celkem 17).
2. **Certificate Consuming Members:** Státy, neprovozující vlastní certifikační schéma, ale certifikáty vydané Authorizing členy plně uznávají na svém území (k březnu 2026 je jich 19).

ČR k dohodě CCRA přistoupila v září **2004** v roli **Certificate Consuming Member**. Smlouvu signoval ředitel NBÚ, nyní spadá pod NÚKIB.

6.2 Status CC v NATO

V roce 2003 padlo v NATO strategické rozhodnutí nahradit zastaralá kritéria (založená na TCSEC) právě standardem CC. Kvůli chybějícímu absolutnímu konsensu všech členských států **nebyl** systém zaveden jako **povinná direktiva**, nýbrž jako **směrnice NATO**. Používání CC v rámci NATO je tedy **doporučené, nikoliv povinné**. Certifikace provedené v rámci národních schémat CCRA členských zemí jsou nicméně uvnitř NATO plně uznávány.

6.3 Metodologie CEM a kritický limit úrovně EAL

Hodnocení probíhá podle jednotné celosvětové metodologie **CEM – Common Evaluation Methodology**.

V listopadu 2022 byla vydána nová, zásadně přepracovaná oficiální verze CEM:2022 Release 1 (společně s CC:2022).

Klíčový limit mezinárodního uznávání: Vzájemné mezinárodní uznávání certifikátů v rámci aliance CCRA je striktně a bezvýhradně *omezeno pouze na úrovně EAL1 až EAL4*. Vyšší úrovně EAL5 až EAL7 vyžadují specifické národní procedury a nejsou předmětem mezinárodního vzájemného uznávání. Nová verze CC:2022/CEM:2022 toto pravidlo nijak nezměnila ani nerozšířila.

6.4 Základní hodnoticí koncepty: Profil ochrany vs. Bezpečnostní cíl

Standard CC se soustředí na formalizované hodnocení produktů pomocí dvou naprosto odlišných dokumentů:

- **Profil ochrany (Protection Profile – PP):** Jedná se o **implementačně nezávislou** sadu bezpečnostních požadavků pro určitý typ technologií (např. obecné požadavky na firewally). Slouží jako *šablona pro kupující* (stát, organizace), kteří jím říkají trhu: “Chceme produkt, který splňuje tyto obecné vlastnosti.” Úspěšně vyhodnocené PP jsou zapsány v *registru certifikovaných profilů*.
- **Bezpečnostní cíl (Security Target – ST):** Jedná se o **implementačně závislou** sadu konkrétních specifikací a bezpečnostních požadavků pro jeden konkrétní produkt (např. konkrétní verze firewallu od konkrétního výrobce). ST přímo popisuje *reálné technické mechanismy* daného řešení a podrobuje se zkoumání hodnotitelů v laboratoři.

6.5 Nová strukturální architektura standardu CC:2022

Dříve CC měla 3 základní části. Verze *CC:2022 Release 1* však standard rozšířila na 5 samostatných dílů:

Part 1	Introduction and general model	Seznámení s filozofií standardu a definice obecného konceptuálního modelu.
Part 2	Security functional requirements (SFR)	Katalog funkčních požadavků na bezpečnostní mechanismy.
Part 3	Security assurance requirements (SAR)	Katalog požadavků na záruky bezpečnosti.
Part 4	Framework for the specification of evaluation methods and activities	(<i>Nový díl</i>) Metodologický rámec specifikující exaktní postupy a činnosti pro schvalování hodnoticích metod reálných laboratoří.
Part 5	Pre-defined packages of security requirements	(<i>Nový díl</i>) Soubor předdefinovaných a předem schválených balíčků bezpečnostních nároků usnadňujících vývoj profilů ochrany.

7 Hlubší struktura Common Criteria, úrovně EAL a schéma EUCC

Nyní navazujeme na základy Common Criteria (ISO/IEC 15408) a zaměřujeme se na praktické stavební kameny, podrobnou charakteristiku úrovní záruk a evropskou integraci certifikace.

7.1 Evoluce a verze standardu CC

Při aplikaci standardu v certifikačních procesech je nezbytné sledovat životní cyklus jeho jednotlivých revizí:

- **Verze 2.3:** Používaná jako autoritativní základ do roku 2007.
- **Verze 3.1:** Publikovaná v září 2007. Přinesla radikální redukci textového rozsahu, zjednodušení interpretačního rámce a snížení počtu tříd a rodin. Dinální vydání *v3.1 Release 5* (z dubna 2017) umožňovala provádění nových laboratorních evaluací pouze do 30. 6. 2024, přičemž platnost vydaných certifikátů je v rámci mezinárodních dohod uznávána do 31. 12. 2027.
- **Verze CC:2022 Release 1:** Vydaná v listopadu 2022. Rozšiřuje architekturu na 5 samostatných dílů rozdělením a procesním posílením oblasti záruk.

Bez ohledu na verzi standardu platí, že dosažená záruka bezpečnosti (např. EAL4) podle jedné verze je plně ekvivalentní stejné záruce podle verze jiné

7.2 Hierarchické stavební prvky kritérií

Pro definování bezpečnostních požadavků (funkčních i zárukových) používá CC striktní hierarchickou granularitu od nejmenšího po největší:

1. **Prvek (Element):** Nejnižší, dále **nedělitelný** bezpečnostní požadavek, který je přímo ověřitelný při hodnocení v laboratoři
2. **Komponenta (Component):** Nejmenší **množina prvků**, kterou lze zahrnout do vyšších struktur (profilů ochrany či bezpečnostních cílů).
3. **Rodina (Family):** Seskupení komponent, které mají stejný bezpečnostní cíl, ale liší se v přísnosti a komplexnosti požadavků.
4. **Třída (Class):** Nejširší seskupení rodin, které pokrývají ucelenou samostatnou oblast bezpečnosti (např. třída pro kryptografickou podporu).

7.3 Katalogizace funkčních tříd a tříd záruk

Funkční požadavky na bezpečnost (SFR – Část 2)

Katalog definuje technické chování produktu. Verze CC:2022 obsahuje stejný počet tříd jako v3.1, ale v odlišném pořadí a s aktualizovaným obsahem:

- | | |
|---|---|
| 1. <i>Audit</i> (Bezpečnostní audit), | 7. <i>Communications</i> (Komunikace), |
| 2. <i>Identification and Authentication</i> (Identifikace a autentizace), | 8. <i>Privacy</i> (Soukromí), |
| 3. <i>Resource Utilisation</i> (Využití zdrojů), | 9. <i>Trusted Path/Channels</i> (Důvěryhodná cesta-/kanály), |
| 4. <i>Cryptographic Support</i> (Kryptografická podpora), | 10. <i>User Data Protection</i> (Ochrana uživatelských dat) a |
| 5. <i>Security Management</i> (Správa bezpečnosti), | 11. <i>Protection of the TOE Security Functions</i> (Ochrana funkcí TSF). |
| 6. <i>TOE Access</i> (Přístup k TOE), | |

Požadavky na záruky bezpečnosti (SAR – Část 3)

Katalog definuje 8 tříd určujících metodiku prověřování správnosti návrhu a vývoje:

- | | |
|---|---|
| 1. <i>Configuration Management</i> (Správa konfigurace), | 7. <i>Life Cycle Support</i> (Podpora životního cyklu), |
| 2. <i>Guidance Documents</i> (Průvodní dokumentace), | 8. <i>Assurance Maintenance</i> (Údržba záruky), |
| 3. <i>Vulnerability Assessment</i> (Posouzení zranitelnosti), | 9. <i>Development</i> (Vývoj) a |
| 4. <i>Delivery and Operation</i> (Dodání a provoz), | 10. <i>Tests</i> (Testy). |

Obsahuje navíc 2 doplňkové třídy pro záruky samotných dokumentů PP a ST.

7.4 Podrobná specifikace úrovní záruk EAL (Evaluation Assurance Levels)

Míry záruky představují předdefinované, vyvážené balíky komponent záruk. Využívá se následující stupnice:

- **EAL1 (Funkčně testováno):** Určeno pro situace, kdy **hrozby nejsou považovány za vážné** a vyžaduje se pouze základní nezávislá důvěra. Zkoumá se neformální funkční specifikace a uživatelské příručky.
- **EAL2 (Strukturálně testováno):** Vyžaduje nízkonákladovou spolupráci vývojáře v rámci běžné komerční praxe. Vývojář dodává globální návrh (high-level design) a své výsledky testů. Analyzují se zjevné zranitelnosti a vyžaduje se seznam konfigurace.
- **EAL3 (Metodicky testováno a kontrolováno):** Lze dosáhnout bez zásadních změn v komerčních vývojových procesech. Navíc oproti EAL2 **vyžaduje kontroly vývojového prostředí a plnohodnotnou správu konfigurace** s rozsáhlejším testováním.
- **EAL4 (Metodicky navrženo, testováno a přezkoumáno):** *Nejvyšší úroveň, kterou lze za rozumné náklady* aplikovat zpětně **na již existující produkt**. Maximální **strop běžné komerční sféry** (banky, PKI). Vyžaduje detailní návrh (low-level design), neformální model bezpečnostní politiky a podmnožinu implementace (část zdrojového kódu). Musí odolat útočníkům s **nízkým potenciálem**.
- **EAL5 (Polo-formálně navrženo a testováno):** Produkt musí být od počátku vyvíjen s tímto cílem. Vyžaduje kompletní zdrojový kód (implementaci), formální model bezpečnostní politiky, polo-formální funkční specifikaci i globální návrh, analýzu skrytých kanálů a modularitu. Musí odolat útočníkům se **středním potenciálem**.
- **EAL6 (Polo-formálně ověřeno a testováno):** Pro ochranu vysoce hodnotných aktiv ve striktním vývojovém prostředí. Vyžaduje polo-formální detailní návrh, zvrstvenou a modulární architekturu a strukturovanou implementaci. Odolnost vůči útočníkům s **vysokým potenciálem** a systematická analýza skrytých kanálů.
- **EAL7 (Formálně navrženo a testováno):** Omezeno na matematicky prokazatelné systémy s úzce vymezenou funkčností v **extrémně rizikovém prostředí**. Vyžaduje plnou formalizaci (formální model, funkční specifikaci i high-level design). Testování probíhá metodou **white-box** s úplným nezávislým potvrzením všech testů laboratoří.

7.5 Ukončení platformy SOG-IS a nástup evropského schématu EUCC

Historická evropská skupina **SOG-IS (Senior Officials Group Information Systems Security)**, k 27. únoru 2026 definitivně **přestala vydávat** nové certifikáty.

Zatímco mezinárodní dohoda CCRA uznává certifikáty plošně pouze do úrovně EAL4, dohoda SOG-IS umožňovala mezi svými 17 evropskými členy vzájemné uznávání certifikátů na vyšších úrovních (EAL5–EAL7) pro specifické, schválené technické domény (např. čipy smart karet, pasy).

Přijetím prováděcího nařízení Evropské komise vzniká jednotný systém **EUCC**, který plně nahrazuje a absorbuje odkaz SOG-IS. Funguje jako **dobrovolný unijní rámec** pro certifikaci ICT HW, SW a čipů.

Prováděcím nařízením Komise (EU) 2024/3144 (s účinností od začátku roku 2025) došlo k zavedení nejmodernějších dokumentů pro akreditaci certifikačních orgánů (CB) a zkušebních laboratoří (ITSEF)

Vazba unijních úrovní záruky na komponentu AVA_VAN

Schéma mapuje unijní úrovně záruky přímo na CC komponentu analýzy zranitelnosti (**Vulnerability Assessment – AVA_VAN**), která zkoumá reálnou zneužitelnost slabin pro kompromitaci funkcí:

Úroveň bezpečnosti EUCC	Hodnocení komponenty CC	Technický význam z hlediska odolnosti
Základní (Basic)	AVA_VAN.1	Ověření odolnosti vůči zřejmým zranitelnostem, základní přehled.
Významná (Substantial)	AVA_VAN.2	Nezávislá analýza zranitelností, potvrzení odolnosti proti nízkému potenciálu útoku.
Vysoká (High)	AVA_VAN.3 až AVA_VAN.5	Hlubkové testování, penetrační zkoušky, garantovaná odolnost proti vysokému potenciálu útoku.

8 Mezinárodní norma ISO/IEC 15408 a funkční požadavky (SFR)

Nyní se budeme věnovat detailnímu rozboru mezinárodní normy ISO/IEC 15408, která představuje formalizovanou implementaci CC v mezinárodním standardizačním procesu, specifikuje strukturu jejích pěti částí a podrobně katalogizuje třídy funkčních požadavků na bezpečnost.

8.1 Standardizační vývoj a národní implementace ČSN

- Česká verze normy **obsahuje výhradně anglický originální text** (překlad do českého jazyka nebyl vydán).
- Původní verze normy z roku 2009 (ISO/IEC 15408-1:2009) byla oficiálně stažena z oběhu a nahrazena verzí z roku 2022 (ISO/IEC 15408-1:2022).
- Distribuci a tisk norem ČSN zajišťuje pro Českou agenturu pro standardizaci (ČAS) smluvní partner TECH-NOR print, s.r.o.

8.2 Struktura pěti částí normy ISO/IEC 15408:2022

Původní verze z roku 2009 (stažena z oběhu) měla pouze 3 části. Nová 2022 verze je striktně rozdělena do 5 částí:

- Part 1: Introduction and general model** – Úvod a obecný model. Představuje klíčové koncepty profilů ochrany (PP), modulů PP, konfigurací PP, balíčků, bezpečnostních cílů (ST) a typů shody. Definuje povolené operace, kterými lze komponenty upravovat, a odkazuje na evaluační metody v ISO/IEC 18045.
- Part 2: Security functional requirements** – Požadavky na bezpečnostní funkce. Definuje požadovanou strukturu a obsah bezpečnostních funkčních komponent (SFR) pro účely hodnocení. Obsahuje kompletní katalog funkčních komponent produktů.
- Part 3: Security assurance requirements** – Požadavky na zajištění bezpečnosti – Definuje jednotlivé součásti zabezpečení a stanovuje exaktní kritéria pro hodnocení PP, PP konfigurací, PP modulů a ST.
- Part 4: Framework for the specification of evaluation methods and activities** – Rámec pro specifikaci metod a činností hodnocení – Poskytuje standardizovaný rámec pro specifikaci objektivních, opakovatelných a reprodukovatelných hodnotících metod a aktivit (nespecifikuje však přímo, jak hodnotit – to je věcí původců metod).
- Part 5: Pre-defined packages of security requirements** – Předdefinované balíčky bezpečnostních požadavků – Obsahuje ucelené skupiny balíčků užitečné pro praxi, konkrétně balíčky EAL (úrovně zaručení vyhodnocení), CAP (balíčky pro zajištění složení), COMP (balíček složených produktů), PPA (zajištění profilu ochrany) a STA (zajištění bezpečnosti cíle zabezpečení).

8.3 Uživatelské skupiny a aplikace standardu v praxi

Norma specifikuje tři základní typy cílových uživatelů a definuje jejich procesní interakci se systémem:

- **Zákazníci (Spotřebitelé):** Vyhledávají existující Profily ochrany (PP) odpovídající jejich nárokům a používají je jako závazný podklad pro specifikaci veřejných i komerčních objednávek. Uživatelská sdružení mohou pomocí CC definovat společné PP pro své členy.
- **Vývojoví pracovníci (Výrobci):** Reagují na požadavky trhu a specifikují bezpečnostní vlastnosti svého konkrétního produktu formou dokumentu Bezpečnostní cíl (ST).
- **Hodnotitelé (Zkušební laboratoře ITSEF):** Využívají požadavky záruky, PP a ST jako exaktní měřítko a závazné kritérium pro provádění nezávislých laboratorních testů.

8.4 Srovnávací charakteristika úrovní EAL a vazba na TCSEC

Norma definuje 7 hierarchických úrovní EAL (Evaluation Assurance Levels), přičemž každá vyšší úroveň plně absorbuje požadavky všech nižších. Pro specifická prostředí je lze volitelně zesilovat (označení +).

- **EAL1 (Funkčně testovaný HP):** Cílová úroveň pro systémy s nízkým rizikem (např. zpracování základních osobních údajů), kde se vyžaduje pouze základní nezávislá důvěra v bezchybný provoz. Hodnocení se odvozuje z artefaktů dostupných běžnému zákazníkovi a nezávislého testování funkčních specifikací. **Je plně proveditelné bez jakékoliv spoluúčasti či asistence vývojáře** za minimálních finančních nákladů.
- **EAL2 (Strukturálně testovaný HP):** Odpovídá třídě *TCSEC C1*. Vyžaduje nízkonákladovou kooperaci s vývojářem, který laboratoři poskytuje základní informace o globálním návrhu (*high-level design*) a výsledky svých interních testů. Typické pro běžné systémy podnikového účetnictví, kde je dostupnost vývojáře časově či procesně omezena.
- **EAL3 (Metodicky testovaný a kontrolovaný HP):** Odpovídá třídě *TCSEC C2*. Představuje maximální možnou úroveň záruky, kterou lze u produktu deklarovat, **aniž by vývojář musel zásadně měnit své zaběhnuté komerční vývojové praktiky** či podstupovat nákladný re-engineering. Zkoumají se důkazy testování technického návrhu na vysoké (zdrojové) úrovni.
- **EAL4 (Metodicky navržený, testovaný a přezkoumáno HP):** Odpovídá třídě *TCSEC B1*. Nejvyšší možný stupeň záruky bezpečnosti, jehož dosažení je ekonomicky, procesně a časově plně integrovatelné do existujících komerčních výrobních postupů (např. u běžně prodávaného síťového či databázového softwaru), pokud je výrobce srozuměn s úhradou dodatečných nákladů na specifické bezpečnostní inženýrství.
- **EAL5 (Semiformálně navržený a testovaný HP):** Odpovídá třídě *TCSEC B2*. Staví na špičkových komerčních vývojových praktikách, které jsou systematicky doplňovány standardní (nikoli extrémní) aplikací specializovaných technik bezpečnostního konstruování, aniž by docházelo k neúnosnému navyšování rozpočtu.
- **EAL6 (Semiformálně navržený se semiformálně ověřeným návrhem a testovaný HP):** Odpovídá třídě *TCSEC B3*. Určeno pro vývoj vysoce pokročilých a propracovaných bezpečnostních produktů cílících na ochranu kritických a cenných aktiv provozovaných ve vysoce rizikových prostředích, kde finální hodnota chráněných dat plně ospravedlňuje masivní vícenáklady.
- **EAL7 (Formálně navržený s formálně ověřeným návrhem a testovaný HP):** Odpovídá třídě *TCSEC A1*. Extrémně nákladná úroveň, jejíž praktická použitelnost je striktně omezena pouze na IT produkty či subsystémy **s velmi úzce zaměřenou a minimální bezpečnostní funkcionalitou**, kterou lze podrobit absolutnímu matematickému a formálnímu ověření.

8.5 Struktura a katalog funkčních tříd (SFR)

Vnitřní dekompozice dokumentu ISO/IEC 15408-2 dělí bezpečnostní požadavky na základě podobnosti funkcí a účelu do **tříd**, ty dále do **rodin** a ty do **komponent**, které jsou v katalozích řazeny abecedně. Na začátku každé třídy je povinně umístěn přehledový strukturní diagram. Kapitoly 3 až 13 popisují celkem 11 funkčních tříd, přičemž přednáška klade důraz na hlubší pochopení dvou z nich:

1. Třída FCO: Komunikace (Communications)

Tato třída obsahuje rodiny komponent zaměřené na bezpečné a nepochybnitelné ověření identity protistran zapojených do procesu síťové výměny a přenosu dat. Garantuje technické mechanismy zajišťující, že odesílatel nemůže popřít odeslání informace a příjemce nemůže popřít její převzetí. Skládá se ze dvou základních rodin:

- **FCO_NRO – Nepopiratelnost původu (Non-repudiation of origin):** Zajišťuje nezvratný a auditovatelný důkaz o identitě původce přenášené informace (důkaz původu).
- **FCO_NRR – Nepopiratelnost přijetí (Non-repudiation of receipt):** Zajišťuje nezvratný a auditovatelný důkaz o identitě příjemce přenášené informace (důkaz přijetí).

2. Třída FCS: Kryptografická podpora (Cryptographic Support)

Aplikuje se povinně v situacích, kdy Předmět hodnocení (TOE) implementuje jakékoliv kryptografické funkce na úrovni hardwaru, firmwaru nebo softwaru, s cílem naplnit bezpečnostní plány vyšší úrovně (např. důvěryhodné kanály, nepopiratelnost, autentizaci entit či izolaci dat). Třída se striktně dekomponuje do dvou rodin komponent:

- **FCS_CKM – Správa kryptografických klíčů:** Řeší kompletní životní cyklus kryptografických klíčů, zahrnující algoritmy pro jejich bezpečné generování, distribuci, ukládání, přístup a bezpečné ničení.
- **FCS_COP – Kryptografické operace:** Zaměřuje se výhradně na technické parametry reálného provozního použití klíčů v kryptografických operacích (např. samotný výkon šifrování, dešifrování, generování digitálních podpisů či výpočet hashovacích funkcí).

Přehled ostatních funkčních tříd v soustavě SFR

Zbývajících 9 tříd pokrývá ostatní oblasti technické bezpečnosti: *FAU* (Bezpečnostní audit), *FDP* (Ochrana uživatelských dat), *FIA* (Identifikace a autentizace), *FMT* (Správa bezpečnosti), *FPR* (Soukromí), *FPT* (Ochrana bezpečnostní funkcionality / Ochrana TSF), *FRU* (Využití zdrojů), *FTA* (Přihlášení do TOE) a *FTP* (Důvěryhodné cesty/kanály).

9 Hodnocení bezpečnosti podle NIST – Standardy FIPS a kryptografické tranzice

Nyní zmapujeme standardizační činnost amerického národního institutu NIST, analyzujeme nelineární model kategorizace bezpečnosti informací dle standardu FIPS 199, popíšeme evoluci požadavků na šifrovací moduly v revizi FIPS 140-3 a přineseme taxativní přehled aktuálních technologických omezení (tranzic) u kryptografických primitiv.

9.1 Institucionální rámec a postkvantová standardizace

NIST (National Institute for Standards and Technology) je ústřední vládní standardizační autoritou USA. Vznikl jako přímý nástupce organizace **NBS** (National Bureau of Standards), založené již v roce 1901. NIST vydává závazné standardy pro potřeby amerických federálních úřadů pod označením **FIPS** (Federal Information Processing Standards), které však vykazují **celosvětovou de facto** autoritu.

V roce **2024** NIST dokončil klíčovou fázi migrace na **quantum-safe** architekturu vydáním finálních textů tří prioritních postkvantových standardů (PQC):

- **FIPS 205:** Stateless Hash-Based Digital Signature Standard (algoritmus SLH-DSA).
- **FIPS 204:** Module-Lattice-Based Digital Signature Standard (algoritmus ML-DSA).
- **FIPS 203:** Module-Lattice-Based Key-Encapsulation Mechanism Standard (mechanismus ML-KEM).

9.2 FIPS 199 – Nelineární kategorizace bezpečnosti informací

Standard FIPS 199 (únor 2004), je určen pro kategorizaci citlivých, avšak **neutajovaných** vládních informací. V evropském a komerčním prostředí se pro tento proces užívá ekvivalentní označení **klasifikace dat**.

Zatímco tradiční systémy klasifikace využívají **lineární hierarchické uspořádání** (Vyhrazeno → Důvěrné → Tajné → Přísně tajné), FIPS 199 definuje **nelineární dvourozměrný model** postavený na matici tří bezpečnostních cílů triády **CIA** a tří stupňů potenciálního dopadu při kompromitaci:

1. **Nízký dopad (LOW):** Ztráta dané vlastnosti má pouze **omezený nepříznivý účinek** na operace organizace, její aktiva či jednotlivce.
2. **Střední dopad (MODERATE):** Ztráta vlastnosti má **vážný nepříznivý účinek** (např. velké materiální ztráty).
3. **Vysoký dopad (HIGH):** Ztráta vlastnosti má **krutý** nebo **katastrofický nepříznivý účinek** (např. přímé ohrožení lidského života).

Tento metodologický přístup rozděluje hodnocení do 9 formalizovaných kombinací (buněk matice), které exaktně slovně specifikují přípustné limity rizik.

9.3 FIPS 140-3 – Bezpečnostní požadavky na kryptografické moduly

Standard FIPS 140 specifikuje technické nároky na HW, SW a firmwarové šifrovací moduly.

Klíčové vlastnosti a procesní změny ve verzi FIPS 140-3

- **Životní cyklus certifikace:** Vydaný certifikát vykazuje platnost po dobu **5 let**. Po uplynutí této lhůty je automaticky přesunut do historického seznamu. Výrobci běžně provádějí kompletní revalidaci v cyklu 3 až 5 let.
- **Provozní režimy:** Modul musí explicitně rozlišovat schválený **FIPS mode** a neschválený **non-FIPS mode** ($FIPS = 0$). Strukturální přechod mezi oběma režimy povinně vyžaduje hardwarový či softwarový restart a novou re-inicializaci.
- **Ochrana proti side-channel útokům:** Nová metodika 140-3 implementuje striktní testovací mechanismy zacílené na potlačení **útoků postranními kanály**, které starší standardy nereflektovaly (jedná se o analýzu časových závislostí, analýzu odběru elektrického proudu a testování odolnosti proti injektáži vynucených chyb).
- **Struktura a role:** Bezpečnostní nároky jsou rozděleny do 11 oblastí harmonizovaných s mezinárodní normou ISO/IEC 19790. V oblasti přístupových oprávnění definuje verze 140-3 jako **jedinou povinnou roli Kryptografického důstojníka (Crypto Officer)**. Role běžného uživatele a administrátora jsou nově volitelné. Veškeré historické textové vazby na armádní standard TCSEC byly eliminovány a nahrazeny přímým odkazem na Common Criteria.

9.4 Čtyři kvalitativní úrovně zabezpečení modulů

- **Level 1 (Basic Security):** Vyžaduje pouze použití schváleného algoritmu a jeho správnou implementaci. **Nejsou stanoveny žádné fyzické bezpečnostní požadavky**. Typické pro čistě SW moduly a knihovny operačních systémů.
- **Level 2 (Enhanced Security):** Přidává fyzické prvky indikující **neoprávněnou manipulaci** (tamper-evident štítky). Vyžaduje autentizaci na základě **rolí** (role-based authentication). Použití: *čipové karty* (smart cards), nižší třídy HSM.
- **Level 3 (Tamper-Resistant):** Zaměřeno na **aktivní odolnost proti fyzickému průniku** (tamper-resistance) s vnitřními senzory, které při **narušení krytu** spustí **aktivní mazání kritických parametrů a klíčů** (zeroization). Vyžaduje **striktní ověření konkrétní identity** (identity-based authentication) a důvěryhodnou cestu (trusted path) pro citlivá data. Využití: bankovní HSM, PKI infrastruktura.
- **Level 4 (Highest Security):** Určeno pro **extrémně riziková a vojenská prostředí**. Modul musí aktivně detekovat a okamžitě reagovat na široké spektrum environmentálních útoků a anomálií (extrémní výkyvy teplot, elektromagnetické pulzy, manipulace s napětím). Fyzické zabezpečení garantuje, že modul zůstane bezpečný i při úplném a agresivním fyzickém napadení.

9.5 Katalog kryptografických tranzic NIST

NIST definuje striktní omezení a provozní statusy pro jednotlivé šifry a parametry délek klíčů:

1. Blokované a symetrické šifry

- **Dvouklíčové 3DES šifrování: ZAKÁZÁNO** pro šifrování; dešifrování je v režimu **překonané/zastaralé**.
- **Tříklíčové 3DES šifrování: ZRUŠENO** pro šifrování po roce 2023; dešifrování tolerováno jako **zastaralé**.
- **SKIPJACK:** Šifrování je **ZAKÁZÁNO**, dešifrování vykazuje status **zastaralého standardu**.
- **AES-128, AES-192 a AES-256:** Plně **POVOLENO** bez jakýchkoliv provozních či časových restrikcí.

2. Asymetrické digitální podpisy (Hranice 112 bitů bezpečnostní síly)

- **Generování digitálního podpisu:**

- Síla < 112 bitů (odpovídá délkám RSA $< 2048b$, ECDSA $< 224b$): **ZAKÁZÁNO**.
- Síla ≥ 112 bitů: Plně **POVOLENO**. V praxi minimální délky: **RSA** $\geq 2048b$, **ECDSA** $\geq 224b$, **EdDSA** $\geq 224b$ a u šifry DSA pouze definované bezpečné dvojice parametrů (L, N) , konkrétně (2048, 224), (2048, 256) nebo (3072, 256).

- **Ověřování digitálního podpisu:**

- Síla $< 112b$: Povoleno výhradně pro zpětnou verifikaci historických dat jako **překonané/zastaralé**.

3. Hašovací funkce

- **SHA-1:**

- Generování digitálního podpisu: **ZAKÁZÁNO** (mimo explicitně povolené specifické výjimky NIST).
- Ověření digitálního podpisu: **Zastaralé / překonané**.
- Ostatní aplikace (např. HMAC, derivace klíčů KDF): Plně **POVOLENO**.

- **Rodina SHA-2 a SHA-3:** Kompletně **POVOLENO** pro veškeré myslitelné kryptografické operace.

- **TupleHash a ParallelHash:** Plně **POVOLENO** pro datové struktury.

10 Normy pro systémy managementu (ISO/IEC 27001 a rodina 27000)

Přednáškový text byl **TLP:AMBER**.

11 Analýza rizik (Zákon č. 264/2025 Sb. a Vyhláška č. 409/2025 Sb.)

Tato přednáška detailně rozebírá proces analýzy rizik (AR) jakožto esenciální aktivitu pro budování a řízení systémů informační bezpečnosti. Definuje základní terminologii na historické analogii, srovnává metodologické přístupy k hodnocení rizik a exaktně mapuje procesní kroky, katalogy a povinnosti vyplývající z nové české kyberbezpečnostní legislativy korespondující s evropským rámcem NIS2.

- **Hrozba (Threat):** Vnější negativní událost, která může zničit či znehodnotit chráněné aktivum.
- **Zranitelnost (Vulnerability):** Vnitřní slabina, díky které hrozba vůbec uspěje.
- **Dopad (Impact):** Následek úspěšného útoku vyjádřený finančně či nefinančně.
- **Opatření (Countermeasure):** Krok ke snížení rizika.

11.1 Typologie analýz rizik podle ISO/IEC TR 13335 a ISO 27005

Normativní rámec (reprezentovaný standardem ISO 27005 pro řízení rizik bezpečnosti informací) rozlišuje tři základní metodologické přístupy k provádění AR:

1. **Elementární (přehledová) analýza:** Rychlé zavedení opatření s nízkými náklady na základě analogie s jinými systémy nebo podle obecného standardu. **Nevýhoda:** Opatření nemusí přesně odpovídat reálným rizikům organizace. Vhodné pro subjekty s nízkou závislostí na IT.
2. **Neformální (pragmatická) analýza:** Staví výhradně na znalostech a zkušenostech expertů bez použití formálních matematických metod. Rizika se expertně dělí na *nepříjemná* (nutno odstranit), *poškozující* (zvážit náklady), *příjemná* (sledovat) a *zanedbatelná*.
3. **Detailní analýza rizik:** Komplexní, formalizovaný proces s přesným oceňováním aktiv, určováním zranitelností a výpočty ztrát (**ALE** – **Annual Loss Expectancy** nebo **EAC** – **Estimated Annual Cost**).

11.2 Procesní kroky AR podle Zákona č. 264/2025 Sb. a Vyhlášky č. 409/2025 Sb.

NÚKIB zásadně aktualizoval šablony v souvislosti s účinností **Zákona č. 264/2025 Sb. (nZKB)** a prováděcí Vyhlášky č. 409/2025 Sb.. V vyšším režimu povinností je AR striktně povinná, v nižším režimu je doporučená a prakticky nezbytná.

- **Krok 1 – Identifikace a evidence aktiv:** Vyhláška striktně nařizuje dělit aktiva na:
Primární aktiva: Informace a služby klíčové pro chod regulované služby.
Podpůrná aktiva: HW, SW, sítě, budovy a lidé, na kterých primární aktiva běží.
Povinné minimum evidence: ID, Název, Popis, Typ/podtyp, Vlastník (Asset Owner), Správce/Provozovatel, Klasifikace, Hodnota/Kritičnost, CIA/DIA klasifikace, Vazby na primární aktiva, Lokalizace, Dodavatel .
- **Krok 2 – Identifikace hrozeb:** Výběr relevantních hrozeb z katalogu vyhlášky (škála 1-4 nebo 1-5; 1=nepravděpodobná, 4=velmi častá).
- **Krok 3 – Identifikace zranitelností:** Výběr vnitřních slabín (1=vysoká odolnost, 4=kritická slabina).
- **Krok 4 – Sestavení scénáře rizika:** Formalizované sestavení vazby: Aktivum + Hrozba + Zranitelnost (např. *SQL databáze + Sociální inženýrství + Chybějící vícefaktorová autentizace MFA*).
- **Krok 5 – Hodnocení dopadu:** Hodnocení na škále 1-5 podle vlivu na CIA a specifických právních povinností (NIS2, eIDAS2, GDPR) . (1=zanedbatelný, 5=kritický)
- **Krok 6 – Hodnocení pravděpodobnosti:** Šance, že hrozba prorazí slabinu, odvozená z existence zranitelnosti, expozice systému a historie incidentů.
- **Krok 7 – Výpočet rizika a kritika čistého násobení:**
Model 1: $P = H \times Z$ a následně $R = D \times P$ (nejpoužívanější model v ČR).
Model 2 (Courtneyho vzorec): Přímý součin $R = D \times H \times Z$.
Důvody opouštění čistého násobení v moderních metodikách NÚKIB:
 1. **Problém absolutní nuly:** Pokud je hrozba ohodnocena 0, vynásobením zmizí celé riziko, přestože v kyberbezpečnosti nulové riziko neexistuje.
 2. **Deformace lineární škály:** Výsledky násobení generují nerovnoměrné skoky (napedř. skok z 16 na 20, pak na 25), což komplikuje férové stanovení hranice akceptovatelnosti.
 3. **Rozměrová nekompatibilita:** Pravděpodobnost je bezrozměrné číslo (či procento), zatímco dopad se měří ve financích či lidských životech; jejich prosté násobení nedává ekonomický ani fyzikální smysl. Moderní praxe proto využívá převodní matice (Risk Matrix).
- **Krok 8 – Zařazení do matice rizik:** Využití matice 5×5 (Osa X: Pravděpodobnost, Osa Y: Dopad), která dělí rizika na *Nízká*, *Střední*, *Vysoká* a *Kritická*.
- **Krok 9 – Návrh bezpečnostních opatření:** Výběr konkrétních prvků z katalogu vyhlášky.
- **Krok 10 – Strategie zvládání a akceptace rizik:** Rozhodnutí o osudu rizika :
Mitigace (Snížení): Použití bezpečnostních opatření.
Transfer (Přenos): Pojištění, outsourcing.
Eliminace (Vyloučení): Zrušení rizikové činnosti.
Akceptace (Přijetí): Vědomé ponechání rizika. **Pravidla akceptace:** Musí být písemně doložitelná v registru, podepisuje ji konkrétní vlastník (top management) a je časově omezená (přezkum typicky 1x ročně). Management musí povinně formálně akceptovat **zbytkové riziko (Residual Risk)**, které po zavedení opatření vždy zbyde.
- **Krok 11 – Pravidelný přezkum:** Minimálně 1x ročně nebo po významné změně.

11.3 Softwarové GRC nástroje pro podporu analýzy rizik

Pro efektivní modelování, automatizaci výpočtů a dlouhodobou správu registru rizik a aktiv se v praxi využívají specializované softwarové platformy:

- **Globální a komerční platformy:** COBRA, *PILAR* (oficiálně podporovaný v rámci struktur EU).
- **Open-source řešení:** Platforma *ERAMBA-GRC*, lucemburský vládní systém **MONARC**

11.4 Převodní terminologická matice dopadů podle NÚKIB

Následující tabulka definuje exaktní legislativní párování doporučeného slovního hodnocení dopadů rizik na kategorizaci vyžadovanou prováděcí vyhláškou k zákonu o kybernetické bezpečnosti:

Terminologie	Věcný popis dopadu v reálném provozu	Stupeň (409/2025 Sb.)
Zanedbatelné	Lze se vypořádat bez větších obtíží.	Nízká
Přípustné	Dopady jsou překonatelné.	Střední
Ohrožující	Dopady ohrožují fungování společnosti.	Vysoká
Neúnosné	Překonatelné jen s velkými obtížemi nebo likvidační.	Kritická

11.5 Strukturální katalogy Vyhlášky č. 409/2025 Sb.

Vyhláška obsahuje závazné katalogové přílohy, které unifikují bezpečnostní procesy:

1. **Katalog hrozeb:** Lidský faktor, technické, síťové hrozby a environmentální hrozby a organizační selhání.
2. **Katalog zranitelností:** Technické, organizační, fyzické a procesní.
3. **Katalog bezpečnostních opatření:** Člení BO do sedmi ucelených oblastí: Organizační opatření, procesní opatření, technická opatření, fyzická opatření, řízení dodavatelů, řízení incidentů, opatření pro kontinuitu.

12 Nový zákon o kybernetické bezpečnosti (zákon č. 264/2025 Sb.)

Nový zákon o kybernetické bezpečnosti (nZKB) představuje zásadní reformu tuzemské legislativy. Kompletně nahrazuje původní a dnes již překonaný zákon č. 181/2014 Sb.. Slouží jako přímá transpozice evropské směrnice NIS2 do českého právního řádu.

12.1 Úvod do problematiky a působnost zákona

Hlavním cílem normy je plošné zvýšení odolnosti státního aparátu, strategických komerčních firem a veřejnoprávních institucí vůči sofistikovaným kybernetickým hrozbám.

- **Účinnost zákona:** Zákon vstoupil v účinnost **1. listopadu 2025**.
- **Rozsah dopadu:** Okruh regulovaných subjektů se dramaticky rozšířil z původních stovek na **až 10 000 organizací**. Zákon dopadá na subjekty usazené v ČR poskytující sítě elektronických komunikací nebo tzv. regulované služby.
- **Vymezení:** Zákon se striktně **nevztahuje na systémy pracující s utajovanými informacemi!** Tyto systémy podléhají zcela jinému právnímu předpisu (zákonu č. 412/2005 Sb.).

12.2 Architektura prováděcích vyhlášek

Zákon se opírá o 3 provázané prováděcí vyhlášky, které upravují technické, organizační a rozřazovací podmínky:

1. **Vyhláška č. 408/2025 Sb., o regulovaných službách:** Definuje, které sektory podléhají regulaci (energetika, doprava, zdravotnictví, finance atd.) a **stanovuje kritéria významnosti**, podle kterých se organizace zařadí do nižšího nebo vyššího režimu.
2. **Vyhláška č. 409/2025 Sb., o bezpečnostních opatřeních pro vyšší režim:** Stanovuje nekompromisní technická a organizační opatření, jako je povinná segmentace sítě, **vícefaktorové ověřování** (MFA), pokročilý log management a striktní řízení dodavatelského řetězce.
3. **Vyhláška č. 410/2025 Sb., o bezpečnostních opatřeních pro nižší režim:** Upravuje mírnější, přiměřená organizační a procesní opatření pro subjekty s nižším dopadem.

12.3 Harmonogram plnění a třífázový model hlášení incidentů

Zákon opouští princip pasivního čekání na státní výzvu a zavádí:

- **Samoidentifikace:** Každá organizace si musí sama na vlastní odpovědnost zjistit, zda do zákona spadá.
- **Lhůta pro ohlášení:** Povinnost ohlásit se u NÚKIB je do 60 dnů od účinnosti zákona (nebo od splnění kritérií). Následuje registrace ze strany NÚKIB.

- **Lhůta pro implementaci:** Organizace má přesně 12 měsíců od formální registrace na to, aby plně zavedla a implementovala všechna povinná bezpečnostní opatření.
- **Osobní odpovědnost:** Za neplnění povinností hrozí pokuty v řádech stovek milionů Kč nebo procenta z globálního obrátu, přičemž osobní odpovědnost nese přímo vrcholový management (představenstvo/vedení).

Pokud v organizaci dojde k incidentu, který naplní kritéria významnosti, nZKB nařizuje striktní hlášení vůči NÚKIB ve **třech po sobě jdoucích fázích**:

1. **Předběžné hlášení incidentu:** Musí být odesláno **do 24 hodin** od detekce incidentu.
2. **Rozšířené hlášení incidentu:** Odesílá se **do 72 hodin** od detekce.
3. **Závěrečná zpráva:** Kompletní zhodnocení incidentu a analýza příčin. Dodána do **1 měsíce**.

12.4 Struktura a kategorizace bezpečnostních rolí

Zákon a vyhlášky zavádějí role, které organizace musí personálně obsadit. Rozlišují se dva statusy:

- **Ano (Explicitní povinnost):** Role je přímo jmenována textem zákona nebo vyhlášky.
- **Ano (Funkční povinnost):** Role není v textu přímo pojmenována, ale povinnosti, které předpis ukládá, **technicky vyžadují, aby tuto agendu někdo vykonával**. Organizace může roli pojmenovat jinak, ale obsahu povinností se nevyhne.

Název role / funkce	Status dle nZKB	Klíčová agenda / Popis
Vrcholový management	Ano	Nese osobní odpovědnost, schvaluje politiky, alokuje finance.
Manažer KB (CISO)	Ano	Kompletně řídí bezpečnost, komunikuje s NÚKIB, odpovídá za rizika.
Vlastník aktiva (Asset Owner)	Ano	Každé aktivum musí mít vlastníka; odpovídá za jeho hodnotu a rizika.
Role pro řízení rizik	Ano	Identifikace aktiv, hrozeb, zranitelností a výpočty scénářů.
Role pro řízení incidentů	Ano	Zachycení útoků, koordinace reakce a hlášení NÚKIB (24h/72h).
Role pro kontinuitu (BCM)	Ano	Tvorba plánů obnovy po havárii, testování a zajištění dostupnosti.
Role pro dodavatelský řetězec	Ano	Prověřování dodavatelského řetězce, smluvní SLA a monitoring.
Role pro správu přístupů (IAM)	Ano	Správa účtů, přidělování oprávnění, princip least privilege.
Role pro technická opatření	Ano	Logování, hardening, segmentace, síťová administrace a záplaty.
Role pro školení a povědomí	Ano	Vzdělávání zaměstnanců, realizace testů (např. cvičný phishing).
Role pro compliance	Ano	Vedení evidencí, příprava podkladů pro dozorové kontroly NÚKIB.
Auditor kybernetické bezpečnosti	Ano (funkčně)	Nezávislé hodnocení plnění zavedených opatření (interní/externí).
Architekt kybernetické bezpečnosti	Ano (funkčně)	Bezpečnostní návrhy systémů, posuzování změn a segmentace.